

网络安全等级保护人工智能系统基本要求初探

黄学臻 吴星禄 翟 翟 吕 由

摘要：人工智能技术的广泛应用在为生活提供极大便利的同时也给网络空间安全增加了许多新的风险因素。由于人工智能应用系统在算法模型、开源框架、数据集等方面存在特有的安全风险，现有的网络安全等级保护体系不能很好地适用于人工智能系统，因此人工智能安全等级保护研究意义重大。在对人工智能系统等级保护对象及安全需求进行充分调研的基础上，提出了人工智能安全等级保护基本要求框架，为完善人工智能等级保护安全基本要求提供了有效参考。

关键词：等级保护；人工智能；网络安全

一、前言

根据《中华人民共和国网络安全法》的要求，明确指出要实施网络安全等级保护制度^[1]。随着我国网络安全等级保护工作从传统信息系统扩展到云计算、移动互联、物联网系统、工业控制系统等新技术、新应用领域，形成了由“安全通用要求+扩展要求”构成的安全要求内容，所涉及到的保护对象和保护技术更加多样化^[2]。针对人工智能系统，目前网络安全等级保护基本要求尚未对人工智能技术提出新的安全要求。近年来，人工智能的安全与隐私问题也越来越受到社会的重视^[3]。我国已经发布了一系列的人工智能相关政策法规及文件^[4-5]，这些文件中均提出了人工智能安全和伦理等方面的要求。因此，需要能够立足于研究适用于人工智能应用的等级保护基本要求，充分兼容现有等级保护标准体系，统筹考虑人工智能技术特征和基础共性的特异性、紧迫性、代表性的安全风险，促进人工智能在新等级保护时代在行业领域的管理和服务安全。

二、人工智能安全风险

人工智能技术的创新性应用系统中，除了存在传统信息系统可能会面临的风险外，给网络空间安全增加了很多新的安全风险。这些风险会存在于输入环节、数据预处理环节、模型训练环节、输出环节^[6]。一是算法模型安全风险。由人工智能模型的复杂和不透明性而引发的安全风险时有发生，尤其是机器模型的训练和部署中可能会遭受恶意攻击使得算法模型设计本身可能会产生错误的结果。例如，攻击者通过修改、删除或者注入特定的数据来对算法模型发起数据投毒攻击，影响模型的训练效果^[6]。二是数据安全风险。人工

智能数据的两个重要威胁是诱饵攻击威胁以及模型窃取威胁。训练数据集对算法模型准确性有极强的影响力。Eykholt等人通过实验证明，对路标覆盖扰动标记可以诱导无人驾驶系统将“停车”标志误识别为“限速”标志^[7]。三是个人信息保护风险。人工智能越来越依赖于训练数据量级和多样性，数据采集、分析处理阶段隐私保护风险突出。Melis等人的研究表明，攻击者在仅拥有训练数据集子集的情况下便可以推断出用户的收入、性别、年龄等相关数据分布^[8]。四是软硬件安全风险。Xiao等人研究发现Tensorflow、Caffe以及Torch这三种常用的深度学习框架中所存在的漏洞可引发深度学习模型识别结果篡改^[9]。综上所述，针对传统系统制定的等级保护标准不能很好地适用于人工智能应用领域。例如，传统的测试技术已经无法满足软件中所使用开源组件的安全测评需求^[10]，因此迫切需要开展对采用人工智能系统的等级保护研究。

三、人工智能应用系统等级保护安全说明

（一）人工智能应用模型场景说明。人工智能系统主要针对系统基础共性提出安全要求，对象包括输入输出设备，原始数据资源和数据集，智能信息处理中的算法框架、计算模型，与现有的《信息安全技术网络安全等级保护基本要求》（GB/T 22239-2019）中安全通用要求以及涉及的安全扩展要求一起构成对采用人工智能系统的等级保护对象的完整安全要求。

（二）人工智能应用系统定级。采用人工智能技术的等级保护对象应作为一个整体对象定级，涉及关键要素：输入输出设备，原始数据资源或数据集，智能信息处理中的算法框架、计算模型。

四、人工智能应用系统保护对象

基于网络安全等级保护防护体系和人工智能的框架机制，可将人工智能应用系统划分为5个层次。人工智能用户层包括管理用户、业务用户。用户层是人工智能应用系统提供服务的交互层，为用户提供访问和管理的功能。人工智能应用服务层包括应用系统、系统业务数据。人工智能技术服务层包括计算框架，算法模型，以及数据集等。这层作为关键技术平台，对外提供解决方案和相关服务。人工智能系统架构层是为人工智能应用系统运行所具备的网络资源、计算资源和存储资源及依托的硬件设备，包括传统信息系统设备，还包括智能输入输出设备，例如新型传感器、智能基础平台等设备。人工智能基础设施层是系统硬件设备的运行物理环境，既有传统系统的物理机房，还有智能终端在数据采集和提供系统服务时的运行环境。管理层针对人工智能系统的全流程全方位管理，对系统进行安全设计管理，防止系统设计将威胁网络安全、社会安全和国家安全，对系统的安全、伦理、隐私问题管理。网络安全方面包括权限管理、网络管理、运维管理、监控管理、安全管理、审计管理等。

五、人工智能应用系统等级保护安全措施

(一) 设计思路。本项目从以下人工智能系统特有的几个关键环节进行研究。1. 物理基础设施安全。针对物理基础设施的硬件安全，数据的输入输出设备或传感器安全。2. 数据安全。针对人工智能系统输入环节的数据集，主要从访问控制、数据存储安全、数据传输安全、个人信息保护方面研究。3. 算法模型安全。针对机器学习模型预处理过程中算法模型的训练数据隐私和模型隐私采取技术措施加以保护，避免模型窃取技术造成的泄露，实现数据存储、数据使用、数据传输的安全。4. 安全管理。人工智能应用深度融合发展，会影响到国家安全、社会安全，人工智能系统设计建设必须满足政策、法律、伦理道德管控和人身安全管控的相关要求。由于人工智能系统所处环境的开放性导致的攻击，针对安全共性需求，主要从安全建设管理、安全运维管理方面进行研究。信息系统全流程管理，对象涉及：人工智能硬件基础设施、核心算法和数据集，数据库比对解决方案以及人工智能信息系统。

(二) 人工智能安全防护措施。网络安全等级保护技术要求中包括安全物理环境、安全通信网络、安全区域边界、安全计算环境、安全管理中心，管理要求中包括安全管理制度、安全管理机构、人员安全管理、

系统建设管理、系统运维管理，构成了十个方面的安全要求，如图1所示。人工智能系统的技术要求中的安全物理环境方面，除了传统物理环境外，增加人工智能专有数据的输入输出设备，以及设备物理位置的安全防护要求。在安全区域边界方面，增加了数据的输入输出安全，例如图像信息、语音数据等数据。在安全计算环境方面，增加了算法框架、计算模型、人工智能系统、数据集、个人隐私信息等人工智能相关的测评对象，加强其安全防护要求。其中数据集包括训练数据、算法模型重要参数、人工智能系统业务数据。在管理要求中，从系统开发的安全、伦理、隐私问题出发，结合技术要求中增加的测评对象，从PPDR模型的安全策略、保护、检测和响应四个部分建立管理体系，规范管理流程。具体在安全管理制度、安全管理机构、人员安全管理、系统建设管理、系统运维管理这五个安全层面增加控制点。

安全层面		测评对象
安全管理制度	安全计算环境	个人隐私信息保护
安全管理机构		数据集安全：采集数据、训练数据、模型隐私数据
安全管理人员		人工智能系统应用安全
安全建设管理	安全区域边界	数据集质量 算法框架安全 计算模型安全
安全运维管理	安全物理环境	输入输出安全
		智能输入输出设备 设备物理位置

图1 网络安全等级保护人工智能安全防护措施

六、人工智能基本要求框架

人工智能基本要求框架主要包括：安全物理环境、安全计算环境、安全管理机构、安全管理人员、安全建设管理和安全运维管理。其中安全计算环境方面包括智能传感器安全、数据预处理安全、算法框架安全、计算模型安全、人工智能应用安全、数据集安全、个人信息保护。

(一) 安全物理环境。人工智能输入输出设备物理防护安全。人工智能输入输出设备所处的物理环境应不对智能输入输出设备造成物理破坏，如挤压、强振动；在工作状态所处物理环境应该不对输入输出设备的正常工作造成影响，如强干扰、输入设备视野阻挡屏蔽等。

(二) 安全区域边界。输入输出安全。应为人工智能系统提供安全的服务接口，保证设备的可用性；采取措施检测恶意构造的攻击信息，实现对系统输入环节的安全增强；采用技术措施增强计算模型输出环节防护。

(三) 安全计算环境。数据预处理安全。在人工

参与的数据预处理环节需要校验环节,保证数据集的准确性与可用性;对输入预处理数据质量进行随机化或者重采样的质量检测。算法框架安全。采用免受恶意代码攻击的技术措施进行算法框架代码漏洞检测,并在经过充分测试评估后,及时修补漏洞;授权用户应在充分测试评估后,对算法框架及时进行版本更新。计算模型安全。对登录计算模型的用户进行身份标识和鉴别,身份标识具有唯一性,身份鉴别信息具有复杂度要求并定期更换;具有登录失败处理功能,应配置并启用结束会话、限制非法登录次数和当登录连接超时自动退出等相关措施;应在发现对抗样本后采取反制措施提升安全防护能力;检测评估智能应用决策行动的健壮性,避免算法歧视造成的决策不公正。人工智能应用安全。对登录的用户进行身份鉴别和访问控制,采用管理机制保证数据共享安全和保密性;对个人隐私数据、原生生物数据和关联生物数据的数据库读、写、创建、修改、删除和脱敏共享等操作权限进行记录。数据集安全。计算模型的隐私数据、标注数据包括关键参数、数据集,应提供泄露数据溯源技术;建立数据集全生命周期管理,确保数据在采集、处理、训练、推理等应用环节等可溯源,防止数据集被污染或遭受投毒攻击。

(四)安全管理制度。建立等级保护对象人工智能应用管理制度,并纳入等级保护对象安全管理制度体系;对管理人员或人工智能输入输出设备操作人员执行的日常管理操作建立操作规程。

(五)安全管理机构。关键岗位人员配备。设立岗位职责明确的系统管理员、安全管理员、审计管理员和操作员等,岗位操作人员应具有相关从业资质,按照最小权限授予原则授予权限,保障安全、相互制约并进行记录备案。

(六)安全管理人员。关键岗位人员管理。进行涉及伦理道德的岗前培训,设置从业门槛,加强从业人员对伦理道德责任的认知;记录和保存第三方人员管理工作记录。

(七)安全建设管理。人工智能应用管控。应用系统建设必须满足政策、法律、伦理道德管控和人身安全管控的相关要求;人工智能应用安全风险等级应和保护措施与部署范围、侵害程度、数据库规模和本地异地部署形式等综合安全风险因素相符。测试验收。对计算模型进行上线前的安全性测试,并出具安全测试报告,安全测试报告应包含计算模型的后门检测、对抗样本检测。

(八)安全运维管理。人工智能输入输出设备监控管理和安全管理中心。应对预处理数据质量、算法

框架漏洞、计算模型检测等技术安全相关事项进行集中管理。系统安全管理。严格控制操作员实施日常用户增删,经过系统管理员授权,安全管理员审核备案,管理部门负责人批准方可实施。

七、结语

近年来,人工智能应多个行业广泛应用,网络规模 and 用户规模都呈现出爆炸性增长,而当前人工智能的网络安全问题也呈现出快速发展的态势。可以预期,针对人工智能安全的研究将在很长一段时间内成为网络安全研究的重点和热点。在当前人工智能发展的初期阶段,本文在考虑人工智能安全需求与安全保障技术的基础上,提出了人工智能安全的等级保护基本要求框架,为完善人工智能等级保护安全基本要求提供参考,推进了人工智能安全标准研制。完全有机会设计结构严谨的人工智能应用系统的等级保护安全要求,使人工智能健康有序发展。□

参考文献

- [1] 中华人民共和国网络安全法[J]. 中华人民共和国最高人民检察院公报,2017(02):1-9.
- [2] 闫珂. 关于网络安全等级保护 2.0 的探讨[J]. 网络空间安全,2021,12(Z3):11-14.
- [3] 陈宇飞,沈超,王骞,等. 人工智能系统安全与隐私风险[J]. 计算机研究与发展,2019,56(10):2135-2150.
- [4] 国务院关于印发新一代人工智能发展规划的通知[J]. 中华人民共和国国务院公报,2017(22):7-21.
- [5] 中华人民共和国数据安全法[J]. 中华人民共和国全国人民代表大会常务委员会公报,2021(05):951-956.
- [6] 周纯毅,陈大卫,王尚,等. 分布式深度学习隐私与安全攻击研究进展与挑战[J]. 计算机研究与发展,2021,58(05):927-943.
- [7] Eykholt K, Evtimov I, Fernandes E, et al. Robust physical-world attacks on deep learning visual classification[C]. Proceedings of the IEEE conference on computer vision and pattern recognition. 2018:1625-1634.
- [8] Melis L, Song C, De Cristofaro E, et al. Exploiting unintended feature leakage in collaborative learning[C]. 2019 IEEE Symposium on Security and Privacy (SP). IEEE, 2019:691-706.
- [9] Xiao Q, Li K, Zhang D, et al. Security risks in deep learning implementations[C]. 2018 IEEE Security and privacy workshops (SPW). IEEE, 2018:123-128.
- [10] 姚允建,王颖.《网络安全等级保护测评报告模板(2019版)》应用研究[J]. 信息网络安全,2020(S2):29-31.

(作者单位:黄学臻、吴星禄、吕由,公安部第一研究所;翟翟,北京交通大学智能交通数据安全与隐私保护技术北京市重点实验室)